FICHE 5 - GÉRER LES HABILITATIONS

Limiter les accès aux seules données dont un utilisateur a besoin.

Respecter le principe de moindre privilège, à travers la gestion des profils d'habilitation, permet de limiter les conséquences d'une usurpation de comptes ou d'une erreur de manipulation.

Les précautions élémentaires

- **Définir des profils d'habilitation** dans les systèmes en séparant les tâches et les domaines de responsabilité, afin de limiter l'accès des utilisateurs aux seules données strictement nécessaires à l'accomplissement de leurs missions.
- **Faire valider toute demande d'habilitation** par un responsable (ex. : supérieur hiérarchique, chef de projet).
- **Supprimer les permissions d'accès des utilisateurs dès qu'ils ne sont plus habilités à accéder à un local ou à une ressource informatique** (ex. : changement de mission ou de poste)**, ainsi qu'à la fin de leur contrat.**
- **Réaliser une revue régulière, au moins annuelle, des habilitations** afin d'identifier et de supprimer les comptes non utilisés et de réaligner les droits accordés sur les fonctions de chaque utilisateur. Les métiers devraient être impliqués dans cette revue afin qu'ils s'assurent de la légitimité opérationnelle des droits attribués.

Ce qu'il ne faut pas faire

- Créer ou utiliser des comptes partagés par plusieurs personnes sans tracer ces exceptions aux règles de sécurité, sans les faire valider par les responsables appropriés et sans les revoir régulièrement.
- Donner des droits d'administrateurs à des utilisateurs n'en ayant pas besoin.
- Accorder à un utilisateur plus de privilèges que nécessaire.
- Oublier de retirer des autorisations temporaires accordées à un utilisateur (ex. : pour un remplacement).
- Oublier de supprimer les comptes utilisateurs des personnes ayant quitté l'organisation ou ayant changé de fonction.

POUR ALLER PLUS LOIN

- Établir, documenter et réexaminer régulièrement **une politique de contrôle d'accès** en rapport avec les traitements mis en œuvre par l'organisation qui doit inclure :
  - les procédures à appliquer systématiquement à l'arrivée ainsi qu'au départ ou au changement d'affectation d'une personne ayant accès à des données personnelles ;
  - les conséquences prévues pour les personnels en cas de non-respect des mesures de sécurité (ex. : utilisation abusive d'un droit d'accès légitime) ;
  - les mesures prévues permettant de restreindre et de contrôler l'attribution et l'utilisation des accès au traitement (voir la fiche n°16 - Tracer les opérations).